

From Data to Accountability: Preparing Health Informatics for the AI Governance Era

Capture Once, Govern Many — hospitals must follow one security law, and it says nothing about whether their AI works. This poster shows what that leaves uncovered, and proposes one shared record that lets every safety framework be answered at once.

Nicole Cevallos

Health Informatics

ACKNOWLEDGED CONTRIBUTOR

Gabrielle Cevallos

METHODS. Structured review of federal rulemaking and executive action, published certification cost data, national breach statistics, AI certification program documentation, and peer-reviewed evidence on deployed clinical AI.



SCAN FOR THE FULL WORKING PAPER & SOURCES

THE PROBLEM

Hospitals are required to follow one framework — and it does not cover AI

Nearly every U.S. healthcare organization holds exactly one mandatory security obligation: **the HIPAA Security Rule**. It governs who may access patient data, and requires audit logs of that access.

It says nothing about the AI itself. Not whether a model is accurate on this hospital's patients, not whether its performance has degraded since purchase, and not what the clinician did with its recommendation.

FINDING 1

The one required framework is also the weakest

The HIPAA Security Rule splits its requirements into “**required**” and “**addressable**.” In practice, addressable has functioned as optional for twenty years — which is why encryption and multi-factor authentication are still not universal in hospitals.

A FIX WAS PROPOSED — AND HAS NOT ARRIVED

Proposed by HHS **December 2024**

Final rule target **July 2027**

Status, August 2026 **Still only a proposal**

FINDING 2

The stronger frameworks are optional — and cost six figures

Frameworks that would cover the rest of the stack do exist. None is mandatory for a hospital, and each must be paid for:

HIPAA Security Rule	Mandatory — but no certificate exists
SOC 2	Tens of thousands
HITRUST	\$35K–\$100K+ (one system: \$500K+)
FedRAMP	\$100Ks to \$1M+
ISO 42001 / NIST AI RMF	Varies; newer in healthcare

So hospitals stay at the floor. Not from negligence — from incentive. Obligation drives implementation, and the obligation stops at the data layer.

FINDING 3

Meanwhile the sector is under attack

772

breaches affecting 500+ people, 2026

2.3

ransomware attacks per day, H1 2026

\$7.42M

average cost per breach

Healthcare has been the most-breached and costliest-breached sector for fourteen consecutive years. Of 410 ransomware attacks in the first half of 2026, 247 struck direct care providers.

FINDING 4 · COVERAGE ANALYSIS

Each framework covers a different layer. Only one is required.

A deployed AI system has five layers. The bars show which framework governs each.

	HIPAA REQUIRED	FedRAMP / NIST 800-53	SOC 2	ISO 42001 / NIST AI RMF	2026 AI certifications
USER / WORKFLOW What the clinician saw and did					COVERED
MODEL Is it accurate? Has it drifted?				COVERED	COVERED
DATA Who accessed the record	COVERED				
INFRASTRUCTURE Servers, configuration, incidents		COVERED			
VENDOR Is the supplier itself trustworthy			COVERED		

Only the **HIPAA** column is mandatory — and it covers one band, the data layer. **The model layer, where AI risk actually lives, is governed only by frameworks nobody is required to hold.**

FINDING 5 · WHAT CHANGED IN 2026

Three AI certifications launched. All say monitor. None says how.

MAY 2026	A health-AI coalition published free governance control catalogs — eight elements, 150+ contributors
JUNE 2026	Two national accreditors launched voluntary, fee-based AI certifications — covering ongoing monitoring, drift and oversight
FEB 2026	A peer-reviewed AI governance maturity model was published — five levels, seven domains

Every one of them requires organizations to monitor their AI. None specifies how the monitoring data is captured.

THE PROPOSAL

Record every AI interaction once. Answer every framework from that record.

1 · HOW YOU COLLECT IT

Six options. Pick by budget.

- A Wrap the AI call
- B Read logs you already keep
- C Watch the screen
- D Send known test cases
- E Compare to a reference
- F Ask staff to report

GREEN = NEEDS NO ENGINEERS AND NO VENDOR COOPERATION

- 2 · WHAT YOU RECORD
One row per AI interaction
which patient
which clinician
which model + version
what it recommended
what the human did
what was produced
where data went
what happened after

3 · WHAT YOU ASK OF IT

One query per framework.

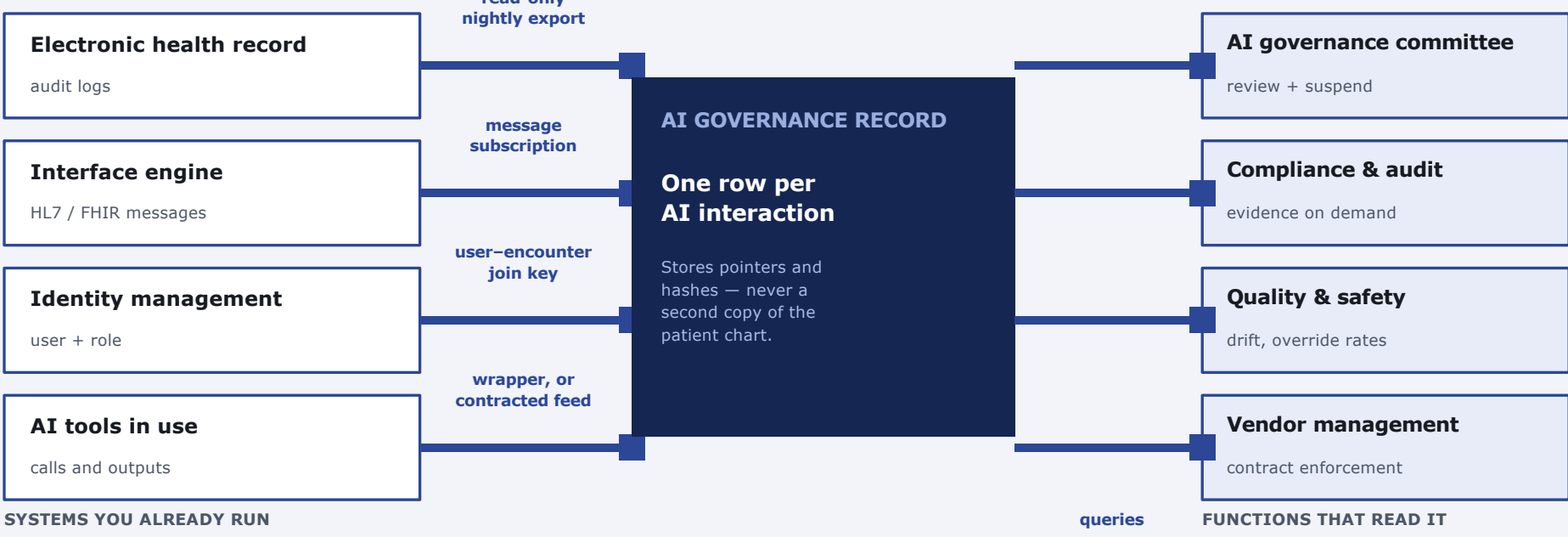
- Access
who touched what — HIPAA
- Boundary
where data left to
- Environment
config + incidents
- Model
still accurate? drifting?
- Human
override rate, behavior

EACH IS A QUERY OVER THE SAME ROW — NOT A NEW SYSTEM

HOW TO DEPLOY IT

Where this attaches in a real health system

Nothing new is installed in the clinical path. Four systems a hospital already runs feed one governance record; four existing functions read from it.



Worked example — a sepsis alert at 03:14. Today the model's score lands in a system log, disconnected from the patient; six months later nobody can say whether the nurse acted or whether the model works here. With one record, the patient, nurse, model version, alert, response and outcome sit in one row.

WHY THIS IS AFFORDABLE

Two observations that make it work

THE RULES ARE FREE. THE AUDIT IS WHAT COSTS MONEY.

A framework is a **free published list of controls** plus a **third-party audit** proving you follow them — and the audit is the \$35K–\$1M. A hospital that cannot afford the audit can still implement the controls: it loses the certificate, not the protection.

THE LOGGING IS ALREADY LEGALLY REQUIRED.

HIPAA has required audit logs — who accessed what, when, for which patient — for twenty years. **Those are nearly the fields an AI monitor needs.** The infrastructure is funded; it has never been pointed at AI.

Cost falls after the first. Capture is paid for once; every added framework is another query over data already recorded.

WHAT AN ORGANIZATION DOES FIRST

Start at the tier you can afford

C0	Any organization, no budget	Read audit logs and message traffic you already keep. Send known test cases through your top three AI tools. Open a channel for staff to report strange output. No engineers. No vendor cooperation. No new software.
C1	With an engineering team	Add a wrapper around AI systems you control — internal tools, API services, agents. Adds real-time visibility into the call itself.
C2	Where the stakes justify it	Add screen-level instrumentation where human behavior is the risk, or a reference model for high-stakes tools. Triggered by a named risk, never adopted by default.

The cheapest tier does real work. Sending known test cases through an AI tool is how clinical laboratories have been required to check instruments for decades. Nobody does it for algorithms.

CONCLUSION

Rules for AI multiplied in 2026. The plumbing that lets a hospital answer them does not exist.

HOW TO PROVE THIS WRONG. Have one hospital start recording AI events at the cheapest tier. If it still cannot answer a single governance question it could not answer before, the argument fails.